

Getting started with AWS Identity and Access Management (AWS IAM)

AWS Prescriptive Guidance

AWS Identity and Access Management (IAM) enables you to manage access to AWS services and resources securely. Using IAM, you can create and manage AWS users and groups, and use permissions to allow and deny their access to AWS resources. This guide covers IAM users, groups, roles, policies, permission boundaries, service control policies, identity federation, IAM Identity Center, and security best practices for implementing a robust access control architecture.

Authors: Elena Petrova and Kwame Mensah, Amazon Web Services (AWS)

Date: January 2026

Table of Contents

- [Introduction](#)
- [IAM Identities](#)
- [IAM Policies](#)
- [Permission Boundaries](#)
- [Service Control Policies \(SCPs\)](#)
- [Identity Federation and SSO](#)
- [IAM Identity Center](#)
- [IAM Roles Anywhere](#)
- [Security Best Practices](#)
- [Auditing and Compliance](#)
- [FAQ](#)

Introduction

AWS IAM is the security foundation of your AWS environment. It controls who is authenticated (signed in) and authorized (has permissions) to use AWS resources. IAM is a global service — users, groups, and roles are not Region-specific. IAM integrates with virtually every AWS service, and most services support resource-level permissions, condition keys, and resource-based policies for fine-grained access control.

IAM uses the principle of least privilege — granting only the permissions necessary to perform a specific task. IAM evaluates all applicable policies before deciding whether to allow or deny a request. By default, all requests are denied. An explicit allow in any applicable policy overrides the default denial. An explicit deny in any applicable policy overrides any allows.

Note: IAM is offered at no additional charge. You pay only for the AWS resources that your users access. There is no limit to the number of IAM users you can create, though service quotas apply to some IAM resources.

IAM Identities

IAM Users

An IAM user is an identity with associated credentials and permissions. Users have a persistent set of credentials — either an access key pair for programmatic access or a username and password for console access. IAM users are intended for human identities that need long-term credentials. For production workloads, AWS strongly recommends using IAM Identity Center for human users rather than creating individual IAM users.

IAM Groups

An IAM group is a collection of IAM users. Groups let you specify permissions for multiple users, which can make it easier to manage permissions for those users. A user can belong to multiple groups. Groups cannot be nested — a group can contain users but not other groups. Groups are a useful way to assign common permissions to teams or roles within your organization.

IAM Roles

An IAM role is an IAM identity that you can create in your account that has specific permissions. A role is intended to be assumable by anyone who needs it — users, applications, or AWS services. Unlike users, roles do not have long-term credentials. Instead, assuming a role provides temporary security credentials (via the AWS Security Token Service, STS) that expire after a configurable duration.

IAM roles are the recommended way to grant permissions to applications running on EC2, ECS, Lambda, and other AWS services. By assigning an IAM role to a compute resource, you eliminate the need to embed access keys in code or configuration files. AWS SDKs automatically discover and use the role credentials via the instance metadata service or environment variables.

IAM Policies

IAM policies are JSON documents that define permissions. A policy specifies the actions (what operations can be performed), the resources (which AWS resources are affected), and the conditions (additional constraints such as IP address or MFA status) under which the actions are allowed or denied.

Policy Type	Attachment Target	Managed By	Primary Use Case
AWS Managed Policy	Users, groups, roles	AWS	Common permission sets maintained by AWS
Customer Managed Policy	Users, groups, roles	You	Custom, reusable permission sets
Inline Policy	Single user, group, or role	You	Specific permissions for one identity
Resource-Based Policy	Resources (S3, KMS, etc.)	You	Cross-account access, resource sharing
Permission Boundary	Users and roles	You	Maximum permission guardrails for delegated admins
SCP (Service Control Policy)	AWS Accounts or OUs	You (via AWS Orgs)	Organization-wide guardrails
Session Policy	Assumed roles	Calling entity	Restrict permissions for specific sessions

Policy Evaluation Logic

When an AWS principal makes a request, IAM evaluates all applicable policies in the following order: (1) Evaluate SCPs from AWS Organizations, (2) Evaluate resource-based policies, (3) Evaluate IAM permission boundaries, (4) Evaluate session policies, (5) Evaluate identity-based policies. An explicit deny at any layer overrides any allows. If no explicit allow is found, the request is denied.

Permission Boundaries

Permission boundaries are an advanced feature that allows you to set the maximum permissions that an IAM entity (user or role) can have. A permission boundary is an IAM managed policy that is attached to a

user or role. The effective permissions of a user or role are the intersection of the permission boundary and the identity-based policies.

Permission boundaries are particularly useful for delegated administration scenarios — allowing developers to create IAM roles for their applications, but only with permissions that are a subset of what the developer themselves can do. This prevents privilege escalation through IAM role creation.

Service Control Policies (SCPs)

SCPs are a type of organization policy that you can use to manage permissions for member accounts in your AWS organization. SCPs act as guardrails, setting the maximum permissions for accounts in your organization. SCPs do not grant permissions — they only restrict what permissions are available. Even if a principal has an IAM policy that allows an action, if an SCP in the organizational hierarchy denies that action, the request will be denied.

Common SCP use cases include preventing member accounts from leaving the organization, restricting which AWS Regions can be used, requiring encryption on all EBS volumes, preventing disabling of CloudTrail, and restricting access to specific EC2 instance types.

Identity Federation and SSO

IAM supports identity federation, allowing you to grant external identities — such as users defined in your corporate directory — access to AWS resources without creating IAM users for them. AWS supports two federation standards: SAML 2.0 and OpenID Connect (OIDC). Web identity federation (using OIDC) allows mobile and web apps to use identity providers such as Amazon, Google, or Facebook to authenticate users and obtain temporary AWS credentials.

IAM Identity Center

AWS IAM Identity Center (formerly AWS SSO) is the recommended way to manage human access to multiple AWS accounts and applications. Identity Center provides a single sign-on experience using your existing identity source — including Active Directory, Okta, Azure AD, or the built-in Identity Center directory. Users access the AWS access portal to see their accounts and applications without managing separate IAM users in each account.

Permission Sets in IAM Identity Center define what level of access a user or group has in an AWS account. Permission sets are similar to IAM roles — they contain IAM policies and are provisioned as IAM roles in the target accounts. You can assign built-in job function permission sets or create custom ones.

Security Best Practices

- Enable MFA for all human users: Require MFA for AWS console access, especially for privileged accounts. Use hardware MFA keys (FIDO2) for root and admin users.
- Never use root account credentials for daily tasks: Lock away the root account credentials and create individual IAM administrator accounts for day-to-day management.
- Grant least privilege: Start with minimum permissions and grant additional permissions only as needed. Use IAM Access Analyzer to identify overly permissive policies.
- Use IAM Identity Center for human users: Manage human access centrally through Identity Center rather than creating individual IAM users in each account.
- Rotate credentials regularly: Establish a credential rotation policy for IAM user access keys. Use IAM credential reports to identify keys that have not been rotated.
- Use roles for applications: Assign IAM roles to EC2 instances, Lambda functions, and other compute resources. Never embed access keys in application code.
- Monitor IAM activity with CloudTrail: Enable CloudTrail in all Regions to log all IAM API calls. Set up CloudWatch Alarms for sensitive actions such as root account usage.
- Use IAM Access Analyzer: Enable IAM Access Analyzer to continuously analyze resource-based policies and identify resources shared with external entities.

Auditing and Compliance

AWS provides several tools for auditing IAM configurations and usage. IAM credential reports list all IAM users in your account and the status of their credentials, including password age, access key age, and MFA status. IAM Access Advisor shows service last accessed data for IAM entities, helping you identify permissions that are not being used and should be removed. IAM policy simulator allows you to test IAM policies before deploying them to production.

AWS Config continuously monitors and records your IAM configuration changes and can evaluate them against desired configurations using AWS Config Rules. Pre-built rules such as `iam-root-access-key-check`, `iam-user-mfa-enabled`, and `access-keys-rotated` help automate compliance checks.

Frequently Asked Questions

Q: What is the difference between IAM roles and IAM users?

A: IAM users have permanent credentials (password and/or access keys) and are intended for human or long-term programmatic access. IAM roles have no permanent credentials — they issue temporary security credentials when assumed. Roles are the recommended way to grant permissions to AWS services, applications, and users who authenticate through an identity provider.

Q: How do I grant cross-account access in AWS?

A: Create an IAM role in the target account with a trust policy that allows principals from the source account to assume it. In the source account, attach an IAM policy that allows the `sts:AssumeRole` action on the role ARN in the target account. Users or roles in the source account can then assume the cross-account role using the AWS STS `AssumeRole` API.

Q: What is IAM Access Analyzer and why should I use it?

A: IAM Access Analyzer helps you identify the resources in your organization and accounts that are shared with an external entity, such as an S3 bucket accessible from another AWS account or the internet. It continuously monitors resource-based policies and generates findings for any external access, helping you detect and remediate unintended access.